Application security review

AI agent permission review - controlled example

Prepared 22 October 2026 | Fix verification

Reviewer: Farouk Hajjej

1. Executive summary

Controlled demonstration, not a customer assessment. A receiving agent is authorized only to summarize a synthetic note. The vulnerable implementation accepts extra permissions claimed by a peer and performs a simulated export outside that task. The supplied fix checks the action against the receiving executor's original allowlist. A fresh local replay on October 22 verified that the export is denied while legitimate summaries still work. No live model or production system was tested.

Recorded results: 1 finding; 0 confirmed open, 0 unresolved, 1 fixed and 0 dismissed.

2. Scope and method

Review coverage	Recorded scope
Reviewed files	3
Deferred / skipped files	0 / 0
Coverage status	Limited review; see assessment boundaries below
Review method	Fix verification; evidence and verification are described below.

Declared scope and limitations

Assessment type: owner-authored, deliberately vulnerable teaching example. It demonstrates the review method, not a discovered customer vulnerability.

Scope: the run_peer_message entrypoint in vulnerable/app.py and fixed/app.py, plus the shared Executor in runtime.py. Other functions in those files were not assessed for this report.

Method: ChatNoir-guided source inspection traced peer-controlled capability claims into action dispatch. The standard-library replay executed both variants with unauthorized and legitimate proposals, then bypassed the fixed gate on one disposable executor instance to check causality.

Reproduction: from the ChatNoir source checkout, run python3 examples/reports/replay-agent-permissions.py. Output includes measured outcomes and SHA-256 source identifiers. All reviewed fixture files remained unchanged.

Not assessed: live model behavior, prompt-injection resistance, distributed sender authentication, production integrations, resource-level permissions, cross-user data access or continuous protection. The simulated export only appends synthetic text to an in-memory list.

Conclusions apply only to the recorded scope and evidence. No overall application security grade is assigned. This document presents supplied review results; generating it performs no additional testing.

3. Detailed findings

AGENT-01: Peer-supplied permissions widen the receiving agent's authority

Fix verified within stated scope | Severity: Medium | Evidence confidence: High

Source location: examples/agent-attacks/vulnerable/app.py:17

Classification: CWE-863

Evidence

1. Trusted policy: Executor.allowed_actions is an immutable allowlist containing only summarize. A peer message is lower-trust input and must not expand that authority.

2. Vulnerable source: run_peer_message copies the trusted allowlist, merges message["capabilities"] into it, and dispatches the peer proposal using that expanded set (lines 15-18).

3. Observed unauthorized proposal: a peer claims the coordinator role, supplies the export capability and proposes that action. The vulnerable path appends one synthetic note to the local export list. The fixed path raises PermissionError before dispatch and records zero exports.

4. Fixed source: run_peer_message calls Executor.authorize on the proposal (fixed/app.py, lines 17-20). The gate validates the exact proposal shape and checks the action against the original allowlist (runtime.py, lines 9-14).

Failure path and impact

1. Initial influence: a peer can supply the sender label, capability list and action proposal accepted by the message handler. No change to the receiving executor's trusted policy is required.

2. Failed boundary: the handler treats peer-provided permissions as authority. A proposed action that the root task never granted reaches the permissive teaching dispatcher.

3. Demonstrated impact: an action outside the summarize-only task is executed. The observed effect is one synthetic in-memory export. Medium severity describes this authorization defect in the fixture; production severity cannot be inferred without real tool permissions and exposure.

Controls and limits on impact

1. Legitimate control: summarize proposals succeed through both variants, with zero exports. The fix therefore preserves the intended workflow.

2. Causality control: bypassing authorize on a fresh, disposable fixed-path executor restores the unauthorized export. Source files are not patched. This shows that the tested gate, rather than a blanket failure to execute actions, prevents the effect.

3. The peer message is supplied directly to an in-process function. No remote identity compromise, model persuasion, data theft or deployment exploit was demonstrated.

Recommended remedy

Authorize each proposal at the receiving action boundary using trusted root-task permissions. Never merge peer-claimed capabilities into that policy. The supplied fixed entrypoint uses the shared authorize gate before dispatch. For a real integration, also validate action arguments and resource ownership at the same boundary; those production controls are outside this fixture.

4. Verification and remaining work

AGENT-01: Fix verified within stated scope

Verification method: Executed local test

Verified locally on October 22, 2026. Unauthorized peer proposal: one synthetic export before the fix; denied with zero exports after it. Legitimate summary: succeeds before and after, with zero exports. Fixed gate bypassed on a disposable executor: one synthetic export returns. The original summarize-only allowlist and all reviewed source digests remained unchanged. Receipt: agent-permissions-replay.json; reproducible with examples/reports/replay-agent-permissions.py.

The recorded verification supports this fix only within the stated test conditions. Deployment and broader security coverage require separate confirmation.

Evidence reference

The identifiers below bind these results to the reviewed source snapshot. They support reproduction and do not establish assessment completeness.

Report data version: ChatNoir 0.2.3

Source inventory SHA-256: 41e5c4b52968152958fd9927d6848946cdec25c840e09ff2a27836f87435d62c

Recorded Git revision: 4dab317b51998bc4fe8152f3f38f4222dac98dd0

Source checkout: Uncommitted changes present; file digests identify reviewed content

examples/agent-attacks/vulnerable/app.py | 681 bytes | SHA-256
635322d13f9f707bc7db23ba4f3eabe41a65b6cb4f0563bc62ea685a1be67fd7

examples/agent-attacks/fixed/app.py | 753 bytes | SHA-256
8f7ce5507371339009cfa89c11452fb2236869f750880a1ef27111d001a66b89

examples/agent-attacks/runtime.py | 1678 bytes | SHA-256
a8f644e3681ec9fd1db64dd40784f5d556d26eae0fa3d7c7c81a723d01b78853

This is a point-in-time, scoped review record, not a security certification. Review confidential report contents before sharing.